ATLAS OS

Security & Data Compliance

Technical & requirements

Program	ATLAS Habitat Initiative
Product	ATLAS OS (Smart admin)
Status	Draft v0.1 — for review by counsel + security lead
Companion docs	Privacy Policy · Data Processing Addendum · Legal & Compliance · Requirements

> **Disclaimer.** Internal framework, **not legal advice or a certification.** Validate with qualified privacy counsel and a security assessor per operating jurisdiction.

1. Applicable regimes

Jurisdiction	Regime
Canada (federal)	PIPEDA (commercial personal data)
Ontario / health	PHIPA if any personal health information is handled (telehealth)
BC / AB / QC	PIPA (BC/AB), Law 25 (QC) where residents are located
United States	State privacy laws (e.g. CCPA/CPRA) on US expansion
Security baseline	SOC 2 (Security, Availability) readiness as the target control framework

2. Data classification

Class	Examples	Handling
Public	Marketing, seed/demo data (no real people)	No restriction
Operational	Floor telemetry, KPIs, incidents	Least privilege; logged
Personal (PII)	Resident contact, broadcast recipients	Minimize, encrypt, retention limited
Sensitive (PHI)	Any telehealth data	PHIPA controls; segregate; avoid storing where possible
Presence	ESP32 presence signals (camera free)	Aggregate/anonymize; no identification

3. Privacy by design

- **Data minimization** — collect only what a feature needs; `FloorMetrics` is sparse.
- **No cameras for presence** — RuView ESP32 presence nodes sense occupancy without imaging.

- **Local first**— the app runs on seed data with no DB; persistence (Neon) is opt in.
- **No PII in seed/demo data** — demos never expose real residents.
- **Purpose limitation** — telemetry is for operations, not resident profiling.

4. Security controls (target)

Domain	Control
Transport	TLS everywhere; HSTS on hosted instances
At rest	Encrypted DB (Neon) + encrypted backups
Access	Least privilege; SSO/MFA for operators; scoped API keys; secrets in env, never in repo
App	Input validation on all POST routes (201/400 contract); dependency scanning in CI
Network	Private DB connectivity; firewalled admin surfaces
Audit	Append only logs for incidents, broadcasts, sensor ingestion; CRA/SR&ED R&D logs retained
Safety boundary	ATLAS OS is observe and advise; it cannot actuate life safety systems

5. Retention & deletion

Data	Default retention
Operational telemetry	24 months rolling (configurable per deployment)
Incidents / broadcasts	Life of tenancy + statutory minimum, then purge
PHI (if any)	Per PHIPA minimums; delete when purpose ends
Audit / SR&ED logs	"e 6 years (CRA audit window)

Residents may request access/correction/erasure (see Privacy Policy); requests actioned within statutory timelines.

6. Sub processors

Maintain a current sub processor list (e.g. hosting/Vercel, database/Neon, email). Each must offer adequate safeguards and a DPA. See DPA.

7. Incident & breach response

1. **Detect & contain** — isolate affected systems; preserve logs.
2. **Assess** — scope, data classes, real risk of significant harm (PIPEDA test).
3. **Notify** — affected individuals + Office of the Privacy Commissioner of Canada (and provincial/health regulators) where the threshold is met; keep a breach record (PIPEDA requires record keeping of all breaches).
4. **Remediate & review** — root cause, fixes, post incident report.

Target timelines: contain "d 24 h; assessment "d 72 h; notification without unreasonable delay.

8. Governance

Named privacy owner + security owner; annual policy review; vendor reviews; access reviews each quarter; this document versioned in repo.

Pair with the Privacy Policy (external) and DPA (B2B) before processing real personal data.